Incident Response Plan: Ransomware Attack on Hodasi Incorporated

A short guide for what a company should do if hackers attack — built around a made-up ransomware (file-locking) attack at a fictional company, **Hodasi Incorporated** (a sports equipment maker and retailer). The company is made up, but the attack pattern is modelled on a real, well-documented ransomware attack on Ireland's public healthcare system in 2021, which outside experts (PWC) investigated afterward.

Scenario

The company: Hodasi Incorporated — about 200 employees, head office in Winnipeg, with a factory, a separate warehouse, and an online store. The important computer systems are: the system that tracks inventory and manufacturing schedules, the warehouse system that tracks orders being picked and packed, the online store (which also stores customer order and payment information), the shared company file drive, and email.

What Happened

When	What happened
Aug 16	An employee in the Accounts Payable department opens an email that looks like it's from a vendor, with an attached invoice file. It's actually a trick — opening it quietly installs hidden harmful software onto their computer. This is where the attack starts.
Sep 1	Antivirus notices the hackers' tools — but nobody follows up.
Oct 5	The hackers reach two more important systems. Antivirus flags it again — still nobody acts.
Oct 9–10	Staff notice odd activity, but it's mistakenly assumed to be a remote warehouse employee just logging in from home with their VPN. Because of this, the company waits before calling in outside help.
Oct 11	Ransomware locks about 75% of the company's systems at once. Manufacturing stops, the website goes down, and orders can't ship. . IT disconnects the company from the internet to stop it from spreading further. This is officially declared a security incident. Full recovery takes about 10 weeks — right through the busiest shopping season.

This plan follows a well-known four-step framework used by security teams (called NIST SP 800-61): Step 1: Preparation; Step 2: Detection & Analysis; Step 3: Containment, Eradication & Recovery; Step 4: Post-Incident Activity. (Ready → Spot the Attack → Stop It and Clean Up → Review What Happened.)

Phase 1: Preparation — Getting Ready Before Anything Happens

This is like a fire drill: Everything must be put in place in case of an emergency

What Happened

Hodasi Incorporated was missing the basics: nobody oversaw handling a security emergency, the company only had antivirus software with nobody watching what it flagged, there was no written or practiced emergency plan, and IT was split into three separate teams (Silos) with no shared way to raise the alarm. No one had an up-to-date list of all the company's computer systems

Solution

- Fix: One person or group should be put in charge of leading the response and must be decided before anything happens.
- Fix: Use security monitoring that gets reviewed by a person, not just antivirus software running in the background with nobody watching, like SIEM (Splunk).
- Fix: write the emergency plan down and practice it once a year.
- Fix: Keep an up-to-date, easy-to-find list of every important computer system across all three parts of the business.

Phase 2: Detection & Analysis — Spotting the Attack

This attack was caught twice — on September 1 and October 5 — and nobody followed up either time. If the company had acted the moment the first warning showed up on September 1, they would have had over five weeks' head start before the hackers caused any real damage on October 11. That five-week gap is the single biggest missed opportunity in this whole story.

- Fix: any detected hacking tool must be looked into within 1 hour — no alert sits unreviewed, however "low priority" it looks.
- Fix: Check the rest of the network for the same warning signs before the hackers get a chance to spread further.

Phase 3: Containment, Eradication & Recovery — Stopping It and Getting Back Online

Stopping It (What Should Have Happened on September 1 and October 5 — Not October 11)

- Disconnect any flagged computer or server the moment hacking tools are confirmed — don't wait for files to start locking up.

- Immediately reset the passwords for any account used on a flagged computer, rather than waiting until there's no other choice.

- Call in outside help immediately once hacking tools are confirmed, instead of spending days debating internally.

Cleaning Up

- Don't try to just "clean" an infected computer or server — wipe it and rebuild it from a known-safe copy. Trying to patch up an infected machine risks missing a hidden backdoor the hackers left behind.
- Figure out exactly how the hackers got in and close that door: in this case, stop allowing email attachments with embedded code (macros) company-wide, since an exception had been made for the Accounts Payable team's vendor invoices.

Getting Back Online

- Always double-check a backup is actually clean before restoring from it. Find the most recent backup and confirm it is clean and not just a backup, then restore the backup in an isolated environment, confirming its validity before bringing the systems back online. Monitor system levels for at least 72 hours after restoring, ensuring an infection does not reappear

Phase 4: Post-Incident Activity — What to Do Afterward

- Hold a short "what went wrong, what went right" meeting involving all 3 Silos, the security team and tell leadership the real cost. How much sales were lost, days of production lost, and what's already fixed.
- Write down the full timeline of what happened (like the one above) and keep it on file for next time.

- Loop in a lawyer before deciding whether customers need to be told about a data exposure. (e.g., Canadian privacy Law may require telling affected customers).
- Apologize to affected customers and offer a goodwill gesture to protect trust and ensure customer loyalty.

Practice Run: Did the Plan Hold Up?

I walked through this scenario step by step, as if I were the one responding, including two curveballs: discovering the recent backups were also infected, and leadership asking whether to notify customers. Both moments exposed gaps that are now built into the plan above — proof that practicing a plan finds problems a written plan alone won't catch.

How My Other Projects Help Here

This plan doesn't stand alone. The biggest failure here was a missed alert — exactly what my home-lab detection project (Project 1) is built to catch automatically, with a real-time alert instead of a silent log. And the entry point was a

phishing email — exactly what my phishing investigation project (Project 2) is built to analyze and flag before anyone opens the attachment.

What This Taught Me

Walking through a real attack pattern, instead of a tidy made-up one, makes the lesson hard to brush off: the actual gap between "we noticed something" (September 1) and "we actually did something" (October 11) was over five weeks. Every rule in this plan closes a specific day in that gap.

Skills This Project Shows

- Applying a recognized industry framework (NIST SP 800-61) to a real-world attack
- Judging how serious a threat is before the damage is done
- Making hard calls under pressure, including real trade-offs
- Knowing when to hand a decision to someone else, like a lawyer
- Turning a real, public security incident into a usable, practical plan

Sources (the real incident this is modeled on)

- Health Service Executive cyberattack — Wikipedia
- HC3: Lessons Learned from the Ransomware Attack on Ireland's HSE — U.S. Dept. of Health & Human Services
- Report dissects Conti ransomware attack on Ireland's HSE — GovInfoSecurity